

AI Identity Security

Project 5

Policy, Compliance and Summary

Submitted By
Sri Vidya Praveena

Project Description

This project consolidates the technical findings of Projects 1 through 4 into formal governance, compliance, and communication artefacts. It defines an AI Identity Security Policy covering the full identity lifecycle, credential governance rules, and a three-scenario incident response playbook. It maps every technical control built across the earlier projects to the NIST AI Risk Management Framework and the OWASP Top 10 for Large Language Model Applications, and identifies remaining compliance gaps. Finally, it packages the entire body of work into a public GitHub portfolio and a risk-prioritized executive summary suitable for a non-technical stakeholder audience.

Objectives of the Project

1. Write a formal AI Identity Security Policy covering identity lifecycle management, credential governance (including a 90-day maximum API key rotation schedule), and a fully detailed incident response playbook for three high-priority scenarios.
2. Build a compliance mapping spreadsheet linking every Project 1-4 control to the NIST AI Risk Management Framework's four core functions (Govern, Map, Measure, Manage) and to the relevant OWASP LLM Top 10 categories, with supporting evidence cited for each.
3. Identify and document three remaining compliance gaps, each with a finding, the underlying obligation, the associated risk, and a concrete recommendation.
4. Publish a structured GitHub portfolio repository containing all five projects, with commit history reflecting the real dates each project was completed.
5. Produce a risk priority matrix and a top-five recommendations summary, written for a non-technical CTO audience, with business rationale and effort estimates for each recommendation.

Policy Title Page and Table of Contents (Screenshot 1):

This screenshot shows the opening page of the AI Identity Security Policy document, including the project title, submission details, and a Table of Contents listing all three required sections - Identity Lifecycle, Credential Governance, and Incident Response Playbook along with the three incident response subsections (3.1, 3.2, 3.3).

What this screenshot shows: the formal cover page of the policy document and its complete Table of Contents, confirming all three required section headings are present before the reader reaches the policy body.

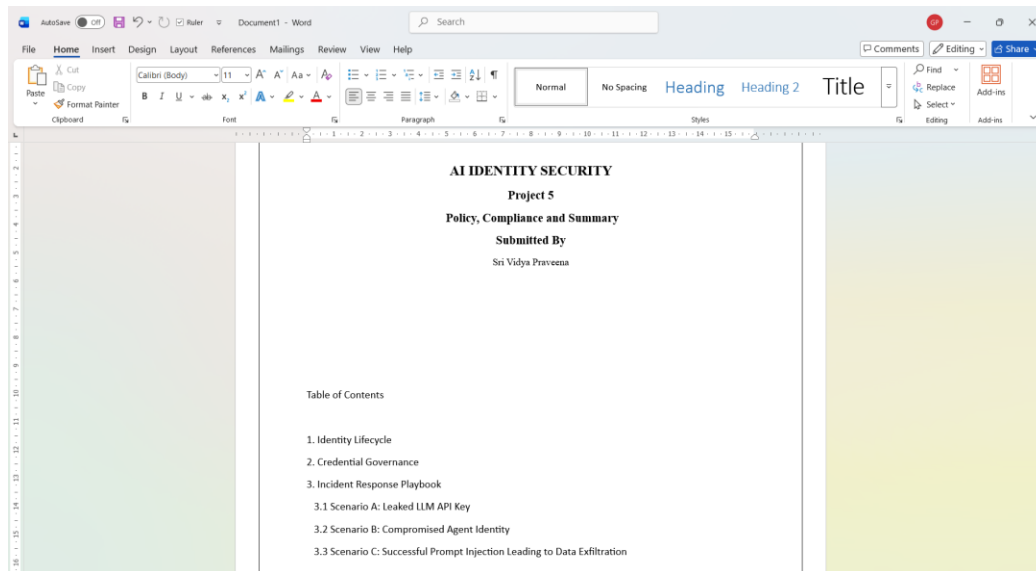


Figure 1: Policy document title page and Table of Contents showing all three required section headings.

Incident Response Playbook ScenarioA Fully Written (Screenshot 2):

This screenshot shows Section 3 of the policy document, specifically Scenario A: Leaked LLM API Key, fully written out with its Detection Signals and Containment steps visible. Detection Signals include unrecognized-IP API key usage, an API_VOLUME_SPIKE alert from the Project 4 anomaly detector, the key appearing in a public repository or secrets-scanning alert, and unexpected billing spikes. Containment steps include revoking the affected key within 15 minutes, issuing a freshly scoped replacement key, and temporarily suspending the agent's outbound API access until the new key is verified.

What this screenshot shows: the written policy text for Incident Response Scenario A, demonstrating that at least one scenario is fully documented with clear, actionable Detection Signals and Containment steps, consistent with the five-part structure (Detection Signals, Containment, Evidence Preservation, Notification, Recovery) used across all three scenarios.

3. Incident Response Playbook

This section defines response procedures for three high-priority AI identity security incidents. Each scenario follows a consistent structure: Detection Signals, Containment, Evidence Preservation, Notification, and Recovery.

3.1 Scenario A: Leaked LLM API Key

Detection Signals:

- API key usage detected from an unrecognized IP address or geographic location.
- Anomaly detector (Project 4) fires an API_VOLUME_SPIKE alert indicating usage inconsistent with the key's normal traffic pattern.
- The key appears in a public code repository, paste site, or is flagged by a secrets-scanning tool (e.g., GitHub secret scanning alert).
- Unexpected billing/usage spike on the associated LLM provider account.

Containment:

- Immediately revoke the affected API key at the provider level (within 15 minutes of confirmed detection).
- Issue a new key with a freshly scoped, minimum-necessary permission set — never reuse the compromised key's identifier.
- Temporarily suspend the affected agent's ability to make outbound LLM API calls until the new key is deployed and verified.

Figure 2: Policy document excerpt showing Incident Response Scenario A — Leaked LLM API Key — with Detection Signals and Containment listed.

Evidence Preservation:

- Export and securely archive all API usage logs covering the suspected exposure window (minimum: 7 days prior to detection through containment).
- Preserve the anomaly detection alert record (timestamp, identity, event type) generated by the Project 4 monitoring system.
- If the leak source is a code repository, preserve the commit history and diff showing when/how the key was exposed, before the repository is cleaned.

Notification:

- Notify the Security team within 1 hour of confirmed detection.
- Notify the owning engineering team and their manager within 4 hours.
- If the leaked key had access to any regulated or customer data, notify Legal/Compliance within 24 hours to assess external disclosure obligations.

Recovery:

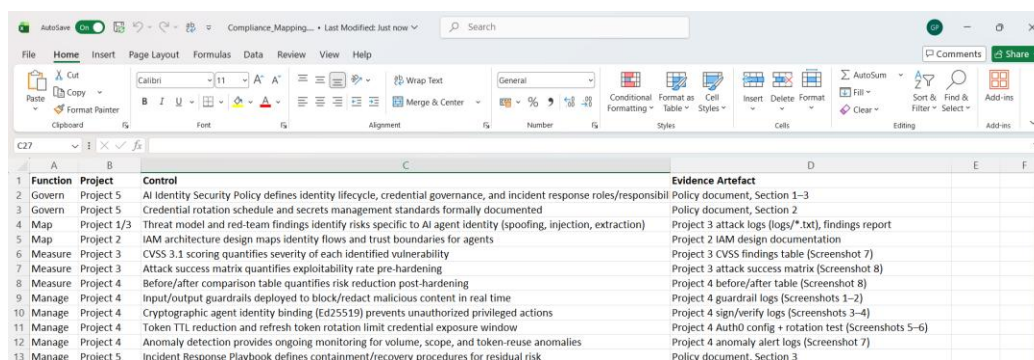
- Confirm the new key is functioning correctly and the old key returns authentication failures.
- Conduct a root-cause review: how was the key exposed (e.g., committed to a repo, logged in plaintext, shared insecurely)?
- Update secrets management practices or tooling (e.g., add pre-commit secret scanning) to prevent recurrence.
- Document the incident in the incident log and close within 5 business days of containment.

Figure 3: Continuation of Scenario A showing the remaining Evidence Preservation, Notification, and Recovery steps.

NIST AI RMF Tab All Four Functions Mapped (Screenshot 3) :

This screenshot shows the NIST_AI_RMF tab of the Compliance Mapping spreadsheet. Every row maps a specific control from Projects 1 through 5 to one of the four NIST AI Risk Management Framework core functions- Govern, Map, Measure, and Manage with a cited evidence artefact for each. For example, the AI Identity Security Policy itself is mapped under Govern (evidence: Policy document, Sections 1-3), the Project 3 red-team findings are mapped under Map (evidence: attack logs and findings report), the CVSS scoring and success-rate data are mapped under Measure (evidence: Screenshots 7-8 from Project 3/4), and the Project 4 guardrails, cryptographic signing, token hardening, and anomaly detection are mapped under Manage (evidence: their respective screenshots and logs).

What this screenshot shows: the complete NIST AI RMF spreadsheet tab with all four functions represented, each row citing a specific, traceable evidence artefact from an earlier project rather than a generic claim.



Function	Project	Control	Evidence Artefact
Govern	Project 5	AI Identity Security Policy defines identity lifecycle, credential governance, and incident response roles/responsibilities	Policy document, Section 1-3
Govern	Project 5	Credential rotation schedule and secrets management standards formally documented	Policy document, Section 2
Map	Project 1/3	Threat model and red-team findings identify risks specific to AI agent identity (spoofing, injection, extraction)	Project 3 attack logs (logs/*_txt), findings report
Map	Project 2	IAM architecture design maps identity flows and trust boundaries for agents	Project 2 IAM design documentation
Measure	Project 3	CVSS 3.1 scoring quantifies severity of each identified vulnerability	Project 3 CVSS findings table (Screenshot 7)
Measure	Project 3	Attack success matrix quantifies exploitability rate pre-hardening	Project 3 attack success matrix (Screenshot 8)
Measure	Project 4	Before/after comparison table quantifies risk reduction post-hardening	Project 4 before/after table (Screenshot 8)
Manage	Project 4	Input/output guardrails deployed to block/redact malicious content in real time	Project 4 guardrail logs (Screenshots 1-2)
Manage	Project 4	Cryptographic agent identity binding [Ed25519] prevents unauthorized privileged actions	Project 4 sign/verify logs (Screenshots 3-4)
Manage	Project 4	Token TTL reduction and refresh token rotation limit credential exposure window	Project 4 Auth0 config + rotation test (Screenshots 5-6)
Manage	Project 4	Anomaly detection provides ongoing monitoring for volume, scope, and token-reuse anomalies	Project 4 anomaly alert logs (Screenshot 7)
Manage	Project 5	Incident Response Playbook defines containment/recovery procedures for residual risk	Policy document, Section 3

Figure 4: NIST AI RMF compliance mapping tab showing all four functions (Govern, Map, Measure, Manage) mapped to project controls with evidence cited.

OWASP LLM Top 10 Tab Attacks Mapped to Controls (Screenshot 4) :

This screenshot shows the OWASP_LLM_Top10 tab of the Compliance Mapping spreadsheet. Each relevant OWASP category LLM01 (Prompt Injection), LLM06 (Sensitive Information Disclosure), LLM07 (System Prompt Leakage), and LLM09 (covering the Agent Identity Spoofing finding under agentic risk) is mapped to the specific Project 3 attack that demonstrated the vulnerability and the specific Project 4 control that mitigates it. For example, LLM01 links the indirect prompt injection attack (3/3 payloads succeeded) to the input guardrail that blocked all three payloads on re-test.

What this screenshot shows: the complete OWASP LLM Top 10 spreadsheet tab, with every category row showing a clear before-and-after pairing between a demonstrated Red Team attack and its corresponding Blue Team control.

OWASP Category	Category Name	Project 3 Attack	Project 4 Control
1	LLM01	Prompt Injection	Indirect Prompt Injection — 3 payloads embedded in documents caused agent to disclose a simulated JWT credential (3/3 succeeded)
2	LLM06	Sensitive Information Disclosure	JWT credential exposed in plaintext within the agent's response, and partial system prompt content leaked via 4/5 extraction techniques
3	LLM07	System Prompt Leakage	System Prompt Extraction — 5 techniques tested (repeat-back, role-play override, translation trick, ignore-prior-instructions, suffix injection); 4/5 succeeded in leaking prompt fragments
4	LLM09	Agent Identity Spoofing (lowers Agent Identity Spoofing under agentic risk)	Agent Identity Spoofing — a message falsely labeled as coming from a trusted orchestrator caused Agent B to execute a privileged delete_user() action without verification
5			Input guardrail using regex heuristic pattern matching blocked all 3 payloads before reaching the agent; output guardrail redacts any JWT-shaped string that still appears in a response
6			Output guardrail (regex-based JWT detection/redaction) prevents credential disclosure; reduced token TTL (300s) limits the value/window input guardrail flags extraction-style phrasing patterns before reaching the agent; role-elevation attempts (user → admin) are blocked by design rule requiring backend-verified authentication of any credential that is disclosed
			Input guardrail flags extraction-style phrasing patterns before reaching the agent; role-elevation attempts (user → admin) are blocked by design rule requiring backend-verified authentication
			E425519 cryptographic message signing and verification ensures only messages with a valid signature from a known private key are accepted; tampered/spoofed messages are rejected with a clear verification error

Figure 5: OWASP LLM Top 10 compliance mapping tab showing each relevant category

GitHub Repository All Five Project Folders (Screenshot 5):

This screenshot shows the root of the capstone_project GitHub repository, listing all five project folders in the file tree: Project 1 (Threat Modelling the AI Identity System), Project 2 (Build and Secure the Auth0-Backed Agent), Project 3 (Red Team: AI Identity Attacks), Project 4 (Blue Team: Guardrails, Hardening and Detection), and Project 5 (Policy, Compliance and Summary). The repository sidebar confirms a total of 62 commits and a single contributor.

What this screenshot shows: the top-level file tree of the published GitHub repository, confirming that all five project folders exist in one place, each named for the project it contains.

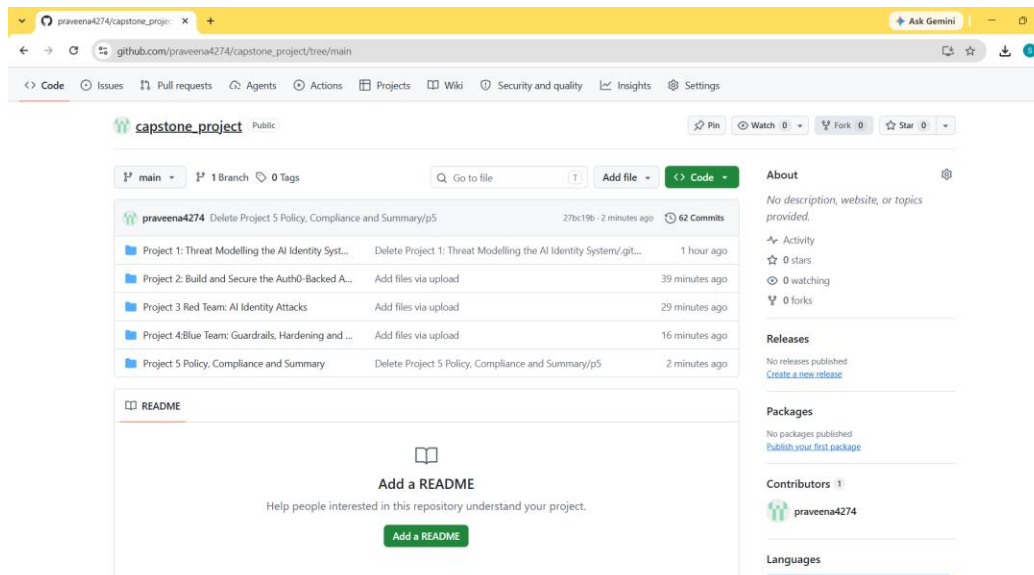


Figure 6: GitHub repository root page showing all five project folders in the file tree.

GitHub Commit History Contributor Graph (Screenshot 6):

This screenshot shows the Contributors graph for the capstone_project repository, displaying 62 total commits from a single contributor. The weekly commit chart shows contribution activity across the repository's history, providing a visual record of the development timeline underlying the five-project submission.

What this screenshot shows: the GitHub Insights → Contributors page, showing the commits-over-time chart and the total commit count for the repository.

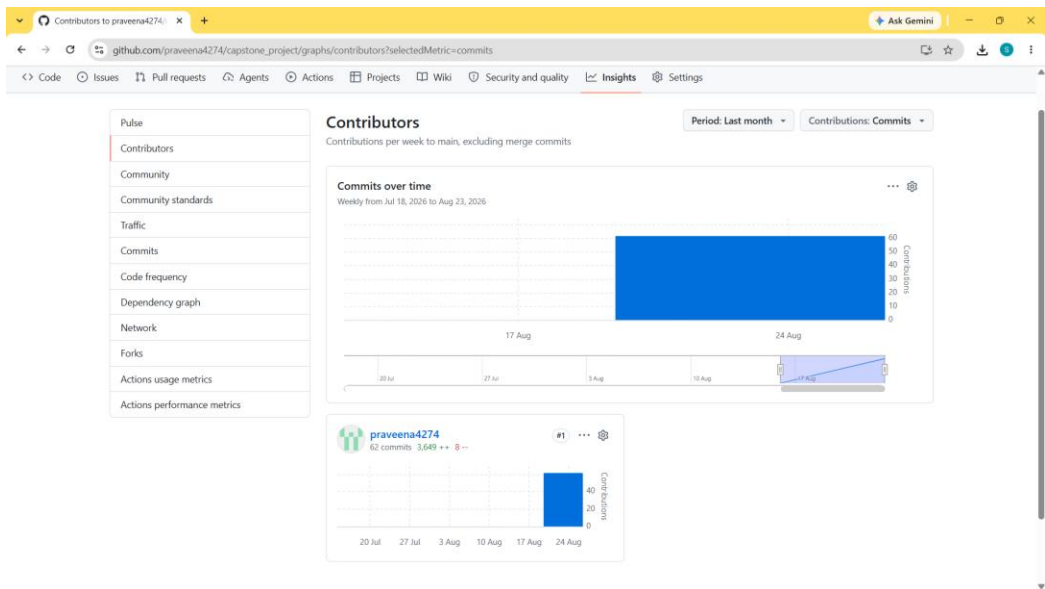
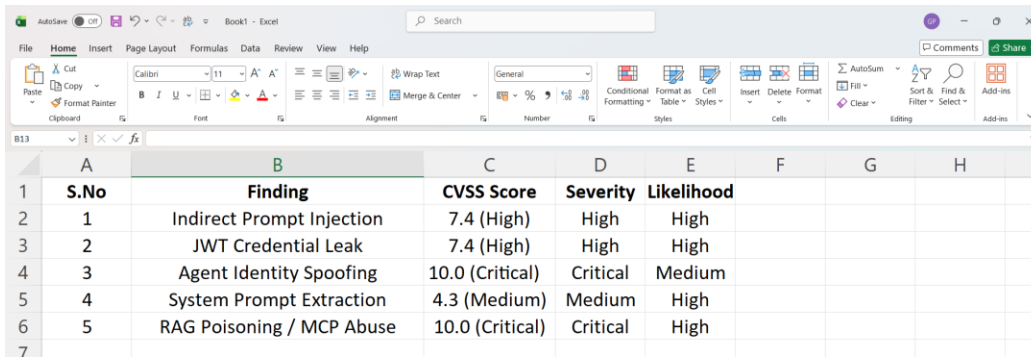


Figure 7: GitHub Contributors graph showing commit activity and total commit count for the capstone_project repository.

Risk Priority Matrix All Five Findings Plotted (Screenshot 7):

This screenshot shows the Risk Priority Matrix listing all five findings from the Project 3/4 assessment, each with its CVSS 3.1 score, severity rating, and likelihood rating: Indirect Prompt Injection (7.4 High, High likelihood), JWT Credential Leak (7.4 High, High likelihood), Agent Identity Spoofing (10.0 Critical, Medium likelihood), System Prompt Extraction (4.3 Medium, High likelihood), and RAG Poisoning/MCP Abuse (10.0 Critical, High likelihood). Plotting severity against likelihood highlights that the two Critical-severity findings, while less frequently triggered in testing, represent the highest-priority remediation targets.

What this screenshot shows: a structured table of all five findings with their CVSS scores, severity, and likelihood ratings recorded side by side, forming the basis of the risk priority matrix referenced in the executive walkthrough.



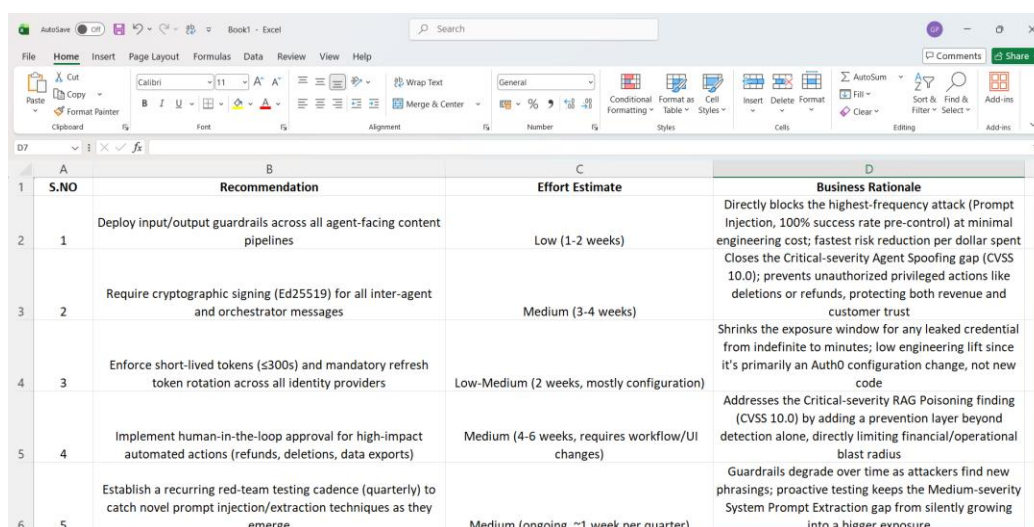
	A	B	C	D	E	F	G	H
	S.No	Finding	CVSS Score	Severity	Likelihood			
1	1	Indirect Prompt Injection	7.4 (High)	High	High			
2	2	JWT Credential Leak	7.4 (High)	High	High			
3	3	Agent Identity Spoofing	10.0 (Critical)	Critical	Medium			
4	4	System Prompt Extraction	4.3 (Medium)	Medium	High			
5	5	RAG Poisoning / MCP Abuse	10.0 (Critical)	Critical	High			

Figure 8: Risk Priority Matrix listing all five findings with CVSS scores, severity, and likelihood ratings.

Top 5 Recommendations Effort and Business Rationale (Screenshot 8):

This screenshot shows the Top 5 Recommendations table, each paired with an effort estimate and a business rationale written for a non-technical audience. The recommendations are: (1) deploy input/output guardrails across all agent-facing content pipelines (Low effort, 1-2 weeks); (2) require cryptographic signing for all inter-agent and orchestrator messages (Medium effort, 3-4 weeks); (3) enforce short-lived tokens and mandatory refresh token rotation across all identity providers (Low-Medium effort, 2 weeks); (4) implement human-in-the-loop approval for high-impact automated actions such as refunds and deletions (Medium effort, 4-6 weeks); and (5) establish a recurring quarterly red-team testing cadence (Medium, ongoing).

What this screenshot shows: the complete Top 5 Recommendations table, with each row showing the recommendation itself, its effort estimate, and a plain-language business rationale explaining why it matters and what it protects.



	A	B	C	D
	S.NO	Recommendation	Effort Estimate	Business Rationale
1	1	Deploy input/output guardrails across all agent-facing content pipelines	Low (1-2 weeks)	Directly blocks the highest-frequency attack (Prompt Injection, 100% success rate pre-control) at minimal engineering cost; fastest risk reduction per dollar spent
2	2	Require cryptographic signing (Ed25519) for all inter-agent and orchestrator messages	Medium (3-4 weeks)	Closes the Critical-severity Agent Spoofing gap (CVSS 10.0); prevents unauthorized privileged actions like deletions or refunds, protecting both revenue and customer trust
3	3	Enforce short-lived tokens (≤300s) and mandatory refresh token rotation across all identity providers	Low-Medium (2 weeks, mostly configuration)	Shrinks the exposure window for any leaked credential from indefinite to minutes; low engineering lift since it's primarily an Auth0 configuration change, not new code
4	4	Implement human-in-the-loop approval for high-impact automated actions (refunds, deletions, data exports)	Medium (4-6 weeks, requires workflow/UI changes)	Addresses the Critical-severity RAG Poisoning finding (CVSS 10.0) by adding a prevention layer beyond detection alone, directly limiting financial/operational blast radius
5	5	Establish a recurring red-team testing cadence (quarterly) to catch novel prompt injection/extraction techniques as they emerge	Medium (ongoing, ~1 week per quarter)	Guardrails degrade over time as attackers find new phrasings; proactive testing keeps the Medium-severity System Prompt Extraction gap from silently growing into a bigger exposure

Figure 9: Top 5 Recommendations table showing effort estimates and business rationale for each recommendation.